

Executive Readiness Report

Management-level summary of scope, findings, risk, evidence readiness and remediation priorities.

Document ID	PCI-V2-ER-001
Prepared by	Richmond Kwadwo Sarpong
Case study	Akwaaba Retail & Online Ltd. (fictional)
Date / version	20 August 2026 / Version 2.0

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

1. Executive Summary

This report summarizes a simulated PCI DSS v4.0.1 readiness assessment for Akwaaba Retail & Online Ltd. (fictional). The fictional merchant operates three retail stores and an e-commerce channel, with approximately 95 staff and 850,000 card transactions per year.

Assessment result: 20 representative gaps were identified - 1 Critical, 11 High and 8 Medium. The merchant has a workable control foundation but is not ready to claim PCI DSS compliance.

20	1	11	8
Representative gaps	Critical	High	Medium

2. Assessment Objectives

- Define the CDE, connected-to systems, people, processes and third-party dependencies.
- Trace card data, tokens, approvals, masked reports, administrative traffic and security logs.
- Evaluate representative control gaps and evidence needed to demonstrate operating effectiveness.
- Translate gaps into business risks, accountable owners, closure evidence and a practical 180-day roadmap.

3. Merchant Profile

Profile item	Fictional scenario
Legal entity	Akwaaba Retail & Online Ltd. (fictional)
Business	Three retail stores plus an e-commerce channel selling household and consumer products
Scale	Approximately 95 staff and 850,000 card transactions per year
Payment channels	E-commerce checkout and attended P2PE-enabled POS terminals
Data policy	No sensitive authentication data retained after authorization; tokens and last four digits used for operations
Assessment basis	PCI DSS v4.0.1 readiness review using the defined approach
Assessment date	19 August 2026

4. Priority Findings

Priority	Risk	Management response
PAN in debug logs	Critical	Immediate containment and secure removal of prohibited data.
Incomplete MFA for CDE access	High	Enforce MFA across all applicable non-console CDE access.
Uncontrolled payment-page scripts	High	Inventory, authorize and monitor scripts for unauthorized change.
Overdue critical vulnerabilities	High	Patch immediately and enforce measurable remediation SLAs.
Inconsistent security monitoring	High	Centralize critical log sources and retain daily review evidence.

5. Evidence Readiness

Requirement-level evidence readiness shows nine families as Partial and three as Missing (Requirements 3, 10 and 11). Missing evidence does not by itself prove a control is absent, but in this simulated readiness case it signals that operating effectiveness cannot be demonstrated consistently.

Req.	Theme	Owner	Readiness
1	Network security controls	Network Lead	Partial
2	Secure configurations	Infrastructure Lead	Partial
3	Stored account data	Data Owner	Missing
4	Transmission protection	Network Lead	Partial
5	Malware protection	Security Operations	Partial
6	Secure systems and software	Engineering Lead	Partial
7	Business-need access	System Owners	Partial
8	Identification and authentication	IAM Lead	Partial
9	Physical access	Facilities / Retail Ops	Partial
10	Logging and monitoring	Security Operations	Missing
11	Security testing	Security Manager	Missing
12	Security program	Compliance Lead	Partial

6. Risk Outlook

The risk register contains four Critical and six High inherent risks. The highest exposure is PAN disclosure through application debug logs (25/25). Target scores assume remediation is fully implemented and independently validated.

ID	Risk scenario	Score	Rating	Target	Owner
R-01	PAN exposure through application debug logs	25	Critical	5	CISO / App Owner
R-02	Unauthorized CDE access because MFA is incomplete	20	Critical	8	IAM Lead
R-03	E-skimming through unauthorized payment-page scripts	20	Critical	8	Engineering Lead
R-04	Exploitation of overdue critical vulnerabilities	20	Critical	5	Infrastructure Lead
R-05	Lateral movement through broad network access	15	High	6	Network Lead
R-06	Delayed detection because key logs are not reviewed	16	High	8	SOC Lead
R-07	Third-party control failure remains unidentified	12	High	6	Compliance Lead
R-08	POS device substitution or tampering	12	High	4	Retail Ops
R-09	Card data interception through weak transport settings	12	High	4	Network Lead
R-10	Ineffective response to a payment-data incident	15	High	6	CISO

7. 180-Day Management Priorities

Day 7

Has prohibited PAN logging stopped and has affected data been handled through an approved process?

Required evidence: Validated log samples, deletion approval and incident decision record

Day 30

Are urgent identity, patching, transport, script and firewall gaps closed?

Required evidence: Passing technical tests, approved rule changes and MFA coverage report

Day 60

Are control owners producing repeatable access, logging, malware and third-party evidence?

Required evidence: Evidence tracker, review tickets, coverage reports and current TPSP assurance

Day 90

Have independent scans, penetration/segmentation tests and the IR exercise confirmed effectiveness?

Required evidence: Passing ASV result, retest reports and approved exercise lessons

Day 180

Is PCI readiness operating as a continuous governance process?

Required evidence: Quarterly dashboard, exception register, risk acceptance and management review

8. Governance and Closure

A remediation item should be considered closed only when the control is implemented, independently checked, and supported by durable evidence. Evidence should be dated, attributable, complete, securely stored and reproducible by an independent reviewer.

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

Acronyms and Definitions

Document-specific reference glossary for **Executive Report**. Definitions are written in plain language for recruiters, reviewers and non-specialist readers.

Acronym	Full meaning and explanation
AOC	Attestation of Compliance A formal declaration that applicable PCI DSS requirements have been assessed.
ASV	Approved Scanning Vendor A company approved by the PCI SSC to perform external vulnerability scanning services.
CDE	Cardholder Data Environment The people, processes and technologies that store, process or transmit cardholder data, or can affect its security.
CHD	Cardholder Data At minimum, the primary account number; it may also include the cardholder name, expiration date or service code.
MFA	Multi-Factor Authentication Authentication using at least two different factor types before access is granted.
PAN	Primary Account Number The payment card number that identifies the issuer and cardholder account.
PCI DSS	Payment Card Industry Data Security Standard The global security standard for protecting payment account data.
PCI SSC	Payment Card Industry Security Standards Council The body that maintains PCI security standards and supporting programs.
QSA	Qualified Security Assessor A PCI SSC-qualified organization or individual that performs PCI DSS assessments.
RACI	Responsible, Accountable, Consulted and Informed A matrix used to clarify roles and decision ownership.
ROC	Report on Compliance A detailed report documenting the results of a PCI DSS assessment.
SAQ	Self-Assessment Questionnaire A validation tool for eligible entities to document PCI DSS self-assessment results.
TPSP	Third-Party Service Provider An external provider whose services store, process, transmit or can affect the security of account data.

Portfolio note: This glossary supports a fictional PCI DSS v4.0.1 readiness case study and does not represent a formal compliance determination.